

Attacks on EtherNet/IP and Migrations through CIP Security

Alexander Gebhard

Marquette University

Milwaukee, WI, USA

alexander.gebhard@marquette.edu

Debbie Perouli

Marquette University

Milwaukee, WI, USA

despoina.perouli@marquette.edu

Abstract—With the Fourth Industrial Revolution (termed “Industry 4.0”), vendors and end users have been integrating Operational Technology (OT) more closely with conventional Information Technology (IT) networks. This allows end users to make real-time decisions, enhance productivity, and leverage up-and-coming technologies such as artificial intelligence in the manufacturing process. However, this does not come without risk. Most protocols that OT devices implement were conceived decades ago, often without any consideration to security. This leaves otherwise insecure devices exposed to IT networks. This paper investigates the security of the EtherNet/IP protocol from an attacker’s perspective. We develop an attack-defense tree of possible man-in-the-middle (MitM) attacks against the EtherNet/IP protocol. We highlight nuances regarding the EtherNet/IP protocol, which make some traditional MitM attacks harder for attackers to execute. Then, we then demonstrate how the semantics of the EtherNet/IP OT protocol can be abused to execute various attacks. Finally, we give an analysis of EtherNet/IP’s countermeasures and a discourse on the challenges of fortifying the EtherNet/IP protocol’s security.

Index Terms—ICS, EtherNet/IP, CIP, security, industrial, protocol, networking

1. Introduction and Motivation

Industrial operators have started the convergence of their Information Technology (IT) and Operation Technology (OT) infrastructures, motivated by the desire to expedite decision-making processes, harness emerging technologies (such as cloud computing and Artificial Intelligence (AI)), and capitalize on advanced analytics capabilities. Termed the fourth industrial revolution or “Industry 4.0”, this paradigm shift underscores a strategic alignment to enhance operational efficiency and competitiveness.

Most OT protocols were designed when it was inconceivable that these insecure protocols would be used across a network. Now, these protocols cross network boundaries and sometimes communicate with other devices over the internet. This new reality has led vendors to incorporate security mechanisms into their otherwise insecure protocols retroactively. Often, many older OT devices cannot adopt these secure OT protocols due to resource constraints or

lack of vendor support. Attackers have been leveraging these insecure protocols to cause havoc on industrial processes.

The security domain is no longer just a simple factory. Today, industrial devices communicate through networks to make real-time manufacturing decisions. Even more alarming, industrial control devices are increasingly connected to the public Internet. Mirian *et al.* [1] conducted a scan over the entire IPv4 address space for the following ICS protocols (Modbus, DNP3, BACnet, Tridium Fox, and Siemens S7) over five months from December 2015 to March 2016. The authors found that over 65,000 exposed devices, including 400 electrical power plants, run the DNP3 protocol. To determine the interest of attackers in these targets, researchers used a network telescope to observe the scanning activity of industrial devices. They discovered more than 22.1 million scans over five months, an average of 160,000 scans daily. Attackers have been observed to do more than probe infrastructure.

In late 2016, actors believed to be affiliated with Russia (APT Sandworm) targeted the Ukrainian power grid with malware called INDUSTROYER [2] (also known as CRASHOVERRIDE). The attackers interacted with power substations through four different ICS protocols (IEC 60870-5-101, IEC 60870-5-104, IEC 61850, and OLE for Process Control Data Access (OPC DA)) to instruct circuit breakers to trip, shutting off power for millions. Attackers have used insecure industrial protocols to shut down operations with great success.

More recently, factions of the popular hacktivist group Anonymous have been attacking the Iranian infrastructure in retaliation for the death of Mahsa Amini [3]. The group has been targeting publicly available EtherNet/IP devices and calling the Shutdown service to disrupt critical infrastructure. Likewise, in 2023, Rockwell Automation, in coordination with the U.S. Government, announced CVE-2023-3595, a remote code execution/DoS vulnerability affecting the EtherNet/IP implementation in some of Rockwell Automation’s communication modules. This vulnerability was found in the wild before an “unnamed” APT (Advanced Persistent Threat) group could leverage it [4]. Attackers have grown increasingly interested in leveraging the EtherNet/IP protocol to carry out attacks against critical infrastructure.

Defenders have not been idle, however. As attackers have been using industrial protocols to further their goals, defend-

ers are retroactively adding security measures to these industrial protocols. Initially created in 2015, CIP Security added security protection to the EtherNet/IP protocol [5]. CIP Security uses DTLS, TLS, X.509v3 certificates, OAuth2.0, and OpenID Connect to provide confidentiality, integrity, authentication, authorization, and access control. A more detailed explanation of CIP Security is provided in Section 6.

OT devices are often very limited in resources (such as RAM, CPU, and storage capacity), making the types of operations they can perform very limited compared to a “traditional” computing device. Additionally, many specifications require devices to perform actions under a strict deadline (it is expected to see motion and safety devices required to perform actions in a couple of milliseconds). These factors make even rudimentary cryptographic tasks, such as Advanced Encryption Standard (AES) operations, challenging as they can incur significant time overheads, rendering them impractical for real-time industrial applications. Given these differences, we present an exploration of attacks against EtherNet/IP.

Our research makes the following contributions:

- We develop an attack-defense tree for the underlying EtherNet/IP protocol
- We highlight the possible ways attackers can abuse the EtherNet/IP protocol
- We highlight the nuances in EtherNet/IP that make MitM attacks different from IT network protocols
- We demonstrate a denial of service attack with EtherNet/IP against a Rockwell Automation ControlLogix 1756-EN4T
- We explore CIP Security and its defense against such attacks

The remaining sections of the paper are as follows. Section 3 provides related work on EtherNet/IP, ADTrees, and industrial protocol security analysis. Section 4 provides a brief background on EtherNet/IP and CIP (Common Industrial Protocol). Section 5 describes the attacks against the EtherNet/IP protocol itself. Section 6 describes implementing a denial of service attack against a Rockwell Automation ControlLogix 1756-EN4T. Section 7 discusses how CIP Security mitigates these types of attacks. Section 8 details mitigations of CIP Security. Finally, Section 9 concludes the report.

2. Related Work

This section details the background of ICS protocol analysis and EtherNet/IP.

2.1. Protocol Analysis

Numerous academic and industry researchers have analyzed different OT network protocols for their security properties. Dzung *et al.* [6] list eight security properties industrial protocols should have, common attack scenarios,

and possible mitigations. Security properties and their definitions are listed in Table 1. While some of the mitigations and attack scenarios are dated, the eight security properties from Dzung *et al.* provide a foundational base to examine the security of industrial protocols.

Property	Description
Confidentiality	Prevent disclosure of data to unauthorized individuals
Integrity	Prevent unauthorized modification of data
Availability	Ensure unauthorized users cannot deny access to authorized users
Authentication	Differentiate between authorized and unauthorized users
Authorization	Prevent users from performing actions who do not have permissions
Auditability	Actions should be logged
Non-reputability	Irrefutable proof that an action has occurred
Third-Party Protection	Averting damage done to third parties via the IT system

TABLE 1. EIGHT SECURITY PROPERTIES FOR SECURE INDUSTRIAL PROTOCOLS FROM DZUNG *et al.* [6]

Researchers have looked at the security of specific protocols them self. The Federal Office for Information Security (BSI) commissioned a study of the OPC UA protocol in 2015 [7] with a follow up study in 2022 [8]. The authors analyze the OPC UA specifications for inconsistencies across the various parts. Despite not finding any conceptual security flaws with the OPC UA protocol, the authors offered dozens of suggestions to improve the security and clarify of the OPC UA specification.

Qassim *et al.* examine the DNP3 protocol and demonstrate its weaknesses to attacks. The authors point out various aspects of the protocol that attackers can use to cause havoc on the electrical grid. In a similar vein, Volkova *et al.* [9] presents the security properties of six industrial protocols: Modbus, OPC UA, TASE.2, DNP3, IEC 60870-5-101, IEC 60870-5-104, and IEC 61850. The authors give a background to each protocol and analyze how these protocols can (or cannot) protect against various attacks or threat actors. The authors found that protocols that comply with IEC 62351 could not protect against all attacks the authors proposed.

2.2. EtherNet/IP

Limited research has been conducted on the EtherNet/IP protocol itself. Researchers have analyzed EtherNet/IP protocol stacks for vulnerabilities, however. Tacliad *et al.* [10] developed ENIP Fuzz, a fuzzer designed to fuzz EtherNet/IP. The authors ran their fuzzer against a Rockwell Automation/Allen-Bradley MicroLogix 1100 PLC and found a denial of service (DoS) vulnerability with the PCCC service of the CIP stack (CISA ICSA-17-138-03). Similarly, Wu *et al.* [11] wrote a fuzzer using SeqGAN artificial intelligence, also called ENIPFuzz. The authors plan to use their fuzzer to test for vulnerabilities in EtherNet/IP

implementations. Ayub *et. al* [12] investigated authentication mechanisms with PLCs and engineering software over various protocols. One device they investigated was the MicroLogix 1100 over EtherNet/IP. The authors found that the password was sent over plain text to the engineering software, which then authenticated the user client-side.

3. EtherNet/IP & CIP

CIP™, or the Common Industrial Protocol, is maintained by the Open DeviceNet Vendors Association (ODVA) [13] through a collective of its members. CIP is a medium-independent protocol – meaning it can run across a variety of physical mediums. It can run through Ethernet (called EtherNet/IP™), Controller Area Network media layer (called DeviceNet™), or through an RG-6 coaxial cable (called ControlNet™). CIP comprises various messages and services to provide functionality to any industrial system, including control, I/O, security, motion, energy, information, and network management. This paper will use EtherNet/IP to describe CIP running over Ethernet. Any reference to CIP refers to the protocol across all physical mediums.

The CIP protocol is very similar to an object-oriented program. At its core, each CIP device contains *objects* which represent a particular function of the system. CIP devices that implement this objects can have one or more *object instances*. These *object instances* are the instantiated version of an object. These objects instances have *attributes* which hold data values. Depending on the specific *object instance*, clients can read and/or write to these data values. Each *object instance* can have services which allow a client to perform actions.

Figure 1 provides a visual representation for the File Object. Files on a CIP device are represented by File Object instances. These File Object instances have attributes such as file name, file size, checksum, and file context. The File Object instances support Upload, Download, Create, and Delete services. Every instance of a particular object has its ID to manage object instances. The CIP specification Volume 1 Chapter 1 [14] and associated documentation [15] details objects in CIP.

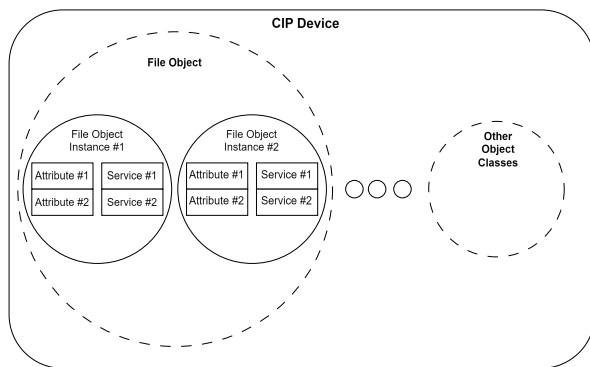


Figure 1. A conceptual example of a CIP Device

3.0.1. Specification. ODVA breaks the CIP specification into nine different volumes. Most of these volumes cover CIP adoption across its various supported physical mediums. In particular interest to security researchers are volume one (introduction to CIP), volume two (EtherNet/IP or CIP over Ethernet) and volume eight (CIP Security). The list of volumes and their topics are below:

- 1) Volume 1: Common Industry Protocol (CIP)
- 2) Volume 2: EtherNet/IP Adaptation of CIP
- 3) Volume 3: DeviceNet Adaptation of CIP
- 4) Volume 4: ControlNet Adaptation of CIP
- 5) Volume 5: CIP Safety
- 6) Volume 6: CompoNet Adaptation of CIP
- 7) Volume 7: Integration of Modbus/HART/IO-Link devices into CIP
- 8) Volume 8: CIP Security
- 9) Volume 9: CIP Motion

Members of ODVA are invited to contribute to the specifications. The specifications themselves are technically open, however they require a fee to access¹.

3.0.2. Connection Types. CIP specifies two modes of communication: connected and unconnected messaging [15]. With connected messaging, the originator (device initiating the connection) establishes a persistent connection with the target. All EtherNet/IP-aware devices between the client and the device (such as EtherNet/IP-aware switches) dedicate resources (such as memory, CPU, and buffers) to maintaining the connection and ensuring timely packet delivery. On the other hand, unconnected messaging is used for sending single, short messages. Unconnected messaging does not guarantee that the EtherNet/IP devices along the path have the resources to process the message. Any device along the path to the target can refuse the packet if it does not have enough resources to handle the request. Connected messaging is commonly used for safety and motion applications, where packets must be delivered quickly. Both message types can be sent using TCP or UDP.

In addition to connected and unconnected messaging, CIP connections can be explicit or implicit [16]. Explicit connections contain a full path to the object on the target device. For example, the path could be: File Object (ID: 0x37), Instance 3, Attribute 1, Get_Attribute. Implicit connections (commonly called I/O) do not contain the information needed to route the object once it gets to the target device. Based on the data it receives, the target device knows which object to route the data to. Implicit connections are commonly used with I/O devices as they continuously send data to a CIP object on the target device. Implicit connections are established using an explicit connection.

3.0.3. Encapsulation Protocol. EtherNet/IP does not run directly on top of TCP/UDP. Instead, ODVA defines a protocol that ensures CIP can remain medium independent, called the “encapsulation protocol.” This protocol has ten

1. The authors have access to the specification for this research.

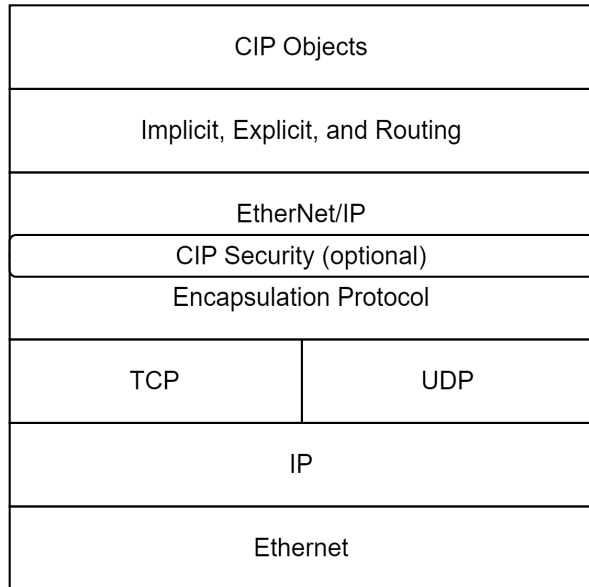


Figure 2. Layers of the EtherNet/IP protocol

commands ranging from session management to retrieving device information. Selected commands are highlighted in Table 2. Every EtherNet/IP message sent over Ethernet uses this encapsulation protocol. Insecure TCP messages are sent over port 44818, while insecure UDP messages are sent over port 2222. Port 2221 is used for secure UDP/TCP transmission. A diagram showing the various protocol layers is shown in Figure 2.

Command	Description
ListIdentity	Retrieves identity and security (if supported) information from the device
RegisterSession (TCP-only)	Creates a session with the device
UnRegisterSession (TCP-only)	Terminates a session with the device
SendRRData	Sends an unconnected EtherNet/IP data message to the device
SendUnitData	Sends an connected EtherNet/IP data message to the device
StartDTLS (UDP only)	Instructs the device to prepare for a DTLS connection

TABLE 2. SELECTED DESCRIPTIONS OF ENCAPSULATION PROTOCOL COMMANDS

4. Attacks on EtherNet/IP

EtherNet/IP is commonly used to configure and program the device, send I/O data, and log diagnostics. This gives attackers much functionality to enable their attacks. To develop our attack model, we assume an attacker is on the same network as an EtherNet/IP device. The capabilities of an attacker depend on whether the attacker is on-path or off-path. On-path attackers place themselves between the originator (a device that initiates the connection) and the

target (EtherNet/IP-speaking device). On-path attackers are powerful as they can observe, insert, drop, replay, modify, and rearrange messages.

On the other hand, off-path attackers are more limited in their capabilities, as they are not between the originator and the target. These attackers are more limited in their types of attacks. Off-path attackers may be able to observe, insert, and replay messages. Either type of attacker has three main ways to interfere with the operation of an EtherNet/IP device: man-in-the-middle, leveraging legitimate vendor services, or abusing protocol specifications.

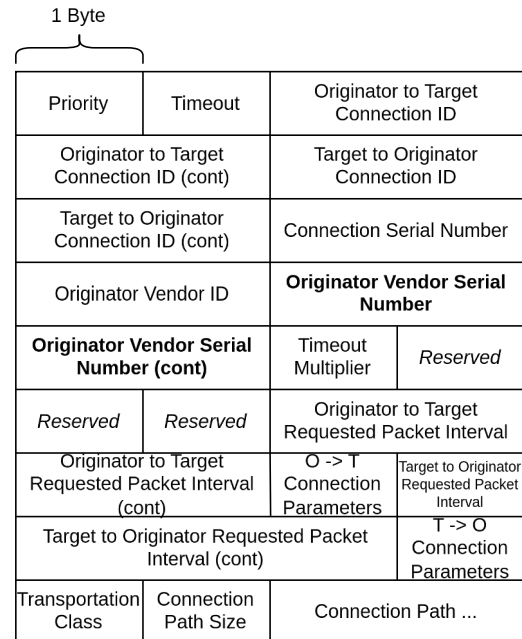


Figure 3. Structure of a Forward_Open request

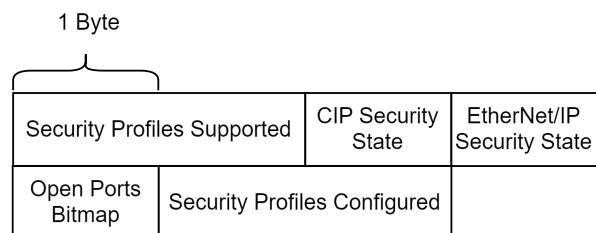


Figure 4. Security fields added to the ListIdentity reply

4.1. Man-in-the-Middle

EtherNet/IP is susceptible to MitM attacks like any protocol without built-in security. A well-placed MitM attack on the EtherNet/IP protocol can have a similar affect as Stuxnet. We have developed an ADTree to demonstrate the effects an attacker can have on the EtherNet/IP protocol in

Figure 6. The leaf nodes in Figure 6 vary depending on the attacker being on-path or off-path. We define an on-path attacker as an attacker who is directly on the communications path between two communicating devices (either by gaining access to a node in the path or by putting themselves in the path). We define an off-path attacker as an attacker who is not on the communications path between two devices, but may still be able to eavesdrop between two communicating devices. On-path attackers are much more powerful than off-path attackers as on-path attackers can modify, drop, or rearrange packets.

Attack-defense Trees (ADTrees) provide a convenient way for defenders to model attack paths and offer mitigations to prevent said attacks. ADTrees were initially proposed by Kordy *et al.* [17] to model interactions between attacks and defenses. Cyber-physical systems research has used attack defense trees to map attacks and mitigations. Hyder and Govindarasu propose extending attack-defense trees with game theory to prioritize defenses in a smart grid [18]. Similarly, Ji *et al.* propose adding return-on-investment and return-of-attack costs to determine which defenses to prioritize [19]. Additionally, Rios *et al.* use attack defense trees to propose a methodology for continuous risk assessment of smart grids [20]. Attack defense trees are not limited to cyber-physical systems, however. They have been used to model attacks and defenses in WordPress platforms [21], cryptocurrencies [22], and autonomous cars [23]. A visual example of an ADTree is shown in Figure 5. The attacker starts at a leaf node, such as retrieving the password. Since the parent node, admin login, has an AND relation, the attacker must capture the username and password to get the administrator login. From there, the attacker can traverse the tree for their ultimate goal of unauthorized server access.

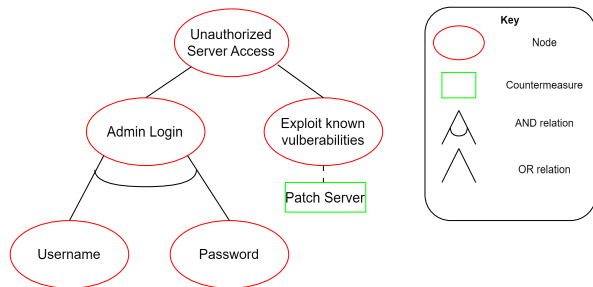


Figure 5. An example ADTree in which an attacker can compromise a server.

ADTree contain attack paths that start from a leaf node, and follow the tree to the ultimate goal (the root node). For example, the attacker would start by conducting an ARP poisoning attack to intercept encapsulation messages from a client to a CIP-enabled device. From there, the attacker can modify, insert, replay, or drop `SendUnitData` or `SendRRData` packets. The attacker would take one of these actions, depending on their goals. The attacker's action would result on a MitM attack on the CIP protocol. As CIP messages are encapsulated via encapsulation protocol

for message transport, any modification/insertion/deletion of encapsulation protocol messages will affect CIP messages.

One of the more interesting MitM attacks stems from intercepting a `ListIdentity` command. The `ListIdentity` command can be sent over unicast or multicast to find other EtherNet/IP devices on a network. Additionally, CIP Security devices can add the following information from Figure 4 to the `ListIdentity` reply. The encapsulation layer is below the TLS/DTLS layer, so the `ListIdentity` reply is not protected. Thus, an attacker can spoof the security state fields to indicate that the device does not support CIP Security and force the connection downgraded to an insecure connection. Devices should not rely on the `ListIdentity` method to determine if a device supports CIP Security.

4.1.1. Limitations. Unlike IT network protocols, EtherNet/IP has interesting scenarios that can limit the capabilities of a man-in-the-middle attack.

I/O Connections: When an I/O connection is established, it is established using an explicit CIP connection, meaning the request has information on which CIP object should handle the request. However, once the I/O connection is set up, the target device will issue a connection ID. The originator will send this connection ID on all subsequent I/O requests. Based on this connection ID, the target device will understand which CIP object to route the request. The connection ID creates a limitation for an attacker. The attacker must observe the establishment of an I/O connection to understand the data being modified. If the attacker does not observe the I/O connection establishment, there will be no clear way to understand the data contained in the packets. To overcome this, an attacker can force the session closed (as outlined in Figure 6). The attacker could also attempt to infer that I/O data is being sent based on the target device.

CIP Routing: As CIP supports a variety of mediums, CIP messages can traverse various physical mediums other than Ethernet, such as Controller Area Network (DeviceNet™), an RG-6 coaxial cable (ControlNet™), or a backplane. Thus, the intended IP address on an Ethernet network packet may not be the final destination for the CIP packet. CIP packets contain routing information to route across network types. For connected messaging, the `Forward_Open` packet contains route information used to establish a persistent connection. CIP-aware devices along the path store routing information observed in the `Forward_Open` in a forwarding table. CIP-aware devices store the CIP session ID with the next hop to forward the packet. Subsequent packets for the CIP session will not contain any routing information. This can create a challenge for a MitM attacker. Any attacker who observes the connection will need to observe the initial `Forward_Open` packet to fully understand the devices on either end of the communication.

This nuance in the CIP protocol has been used to hop security boundaries. Claroty researchers found that routing a CIP packet through a trusted device on a backplane will bypass Rockwell Automation's trusted slot feature on Con-

trolLogix 1756 devices (CVE-2024-6242) [24]. The trusted slot feature is designed to prevent two modules from communicating on a backplane [25]. It appears that the target device only checked the previous hop to determine if a module is trusted. Claroty researchers found that as long as the last hop to the target device is trusted, any module on the blackplane can communicate with the target device regardless if it is considered trusted.

4.2. Abuse of Vendor Functionality

CIP allows vendors to extend and implement vendor-defined objects further their device's capabilities. ODVA gives the following ranges for object IDs [14]:

Object ID Range	Type	Quantity
0x00 – 0x63	Specified by ODVA	100
0x64 – 0xC7	Vendor Specific	100
0xC8 – 0xEF	Reserved for future use	40
0xF0 – 0x2FF	Specified by ODVA	528
0x300 – 0x4FF	Vendor Specific	512
0x500 – 0xFFFF	Reserved for future use	64,256

TABLE 3. CIP OBJECT ID RANGES

We've created a tool in Rust to scan a CIP device for implemented objects. This tool queries the entire object range to determine which objects are implemented by the device. Once the tool finds an object, it attempts to find supported attributes and services. We scanned the Rockwell Automation 1756-EN4T in its default configuration and found thirty-four objects implemented (seventeen open and seventeen vendor-specified objects). The Rockwell Automation 1756-L85EP CPU implements eighty one CIP objects (eighteen open and sixty three vendor specified objects). These objects give attackers leeway to modify the functionality of a device.

Attackers have leveraged this legitimate functionality to significant effect. As mentioned, hackers have used the CIP protocol to cause DoS to Rockwell Automation CIP devices using the Metasploit module to execute the Shutdown service (Service: 0x36) on the Identity Object (Class: 0x01). Not only could attackers shut down a device, but the CIP specification defines various objects attackers can use to modify or disrupt device functionality.

4.3. Misusing Protocol Specifications

As mentioned, CIP defines a method for devices to establish a persistent path between two nodes on a network called connected messaging. Any device capable of understanding CIP between these nodes should reserve resources (such as RAM, CPU, and buffer space) to maintain this connection. The steps to establishing this persistent path are shown below:

- 1) To establish a persistent connection between two devices, the originator (client) will send a `Forward_Open` to the target (device). The format of the `Forward_Open` request is shown in Figure 3.

- 2) The CIP-capable switch between the originator and target will receive the `Forward_Open`. If the switch can adequately allocate resources to maintain the connection, it will pass the packet to the target. Otherwise, the switch will return a CIP error.
- 3) The target will successfully respond and generate its connection ID.

An attacker can misuse this functionality to create a denial of service condition. By creating many bogus `Forward_Opens`, an attacker can reserve resources on the device that are not actively used. We demonstrate the simplicity of exploiting this functionality in the next section.

5. Attack Implementations

This section explains how we abused CIP's `Forward_Open` command to execute a DoS attack against a Rockwell Automation 1756-EN4T.

5.1. Setup

To execute the denial of service attack using a `Forward_Open`, we set up a simple testbed using an attacker device (Raspberry Pi 5), a Rockwell Automation 1756-EN4T, and a Rockwell Automation 1756-L85EP connected to the same backplane. An image of this is shown in Figure 7.

5.2. Forward_Open Denial of Service

To test a denial of service using a `Forward_Open`, we set up a Rockwell Automation 1756-EN4T and a Rockwell Automation 1756-L85EP on the same backplane. We created a test program to send many `Forward_Open` requests to the 1756-L85EP module through the 1756-EN4T. We found that we could send many `Forward_Open` requests on the same TCP connection, simply by changing the originator's serial number (bold in Figure 3). The 1756-EN4T could handle a variable amount of `Forward_Open` requests. After powering the device up, we found that it would handle 108 `Forward_Open` requests before CIP returned an error. Any other device that connects and requests a connected session will be rejected. However, the number of possible `Forward_Open` appears to change based on the amount of buffer space currently in use for other tasks. Additionally, we found that as long as the TCP connection is active, these `Forward_Open` sessions will be maintained until they expire (assuming the EtherNet/IP session remains active). Proper network monitoring can ensure the detection of this attack.

6. CIP Protocol Security Overview

Initially released in 2015, CIP Security is an *optional* extension to the CIP protocol that provides security properties to the CIP protocol. CIP Security is specified in Volume

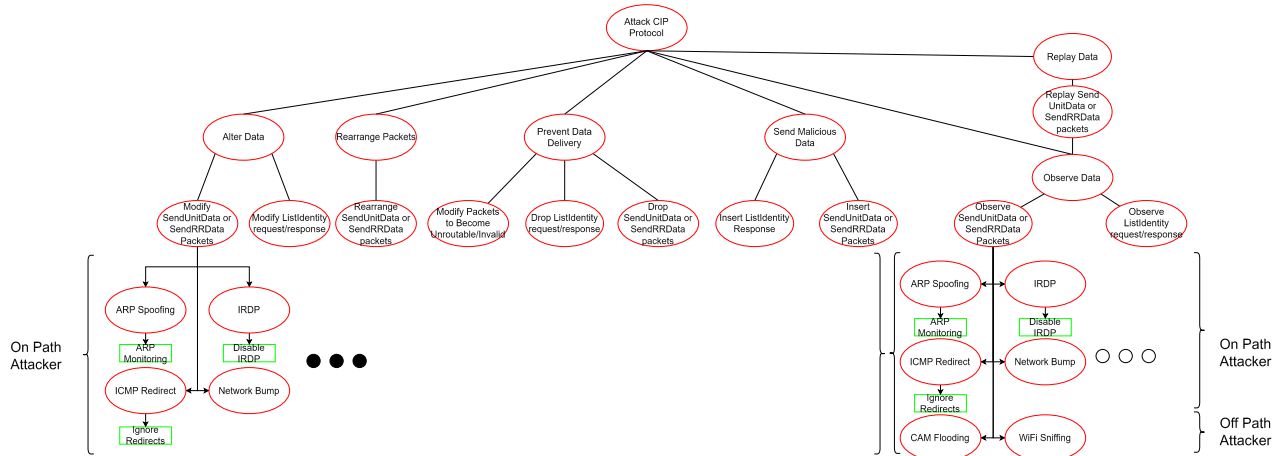


Figure 6. An attack-defense tree (ADTree) demonstrating possible attacks against EtherNet/IP Encapsulation Protocol



Figure 7. Picture of the setup used in Part 5

Object Name	Description
CIPSecurity	Provides services to allow exclusive access to modify security configuration
EtherNetIPSecurity	Provides attributes and services to modify (D)TLS settings
CertificateManagement	Provides an interface to manage a device's X.509v3 certificate
Authority	Provides services and attributes to authenticate against an external Authority (See section 6.2.2)
PasswordAuthenticator	Provides services and attributes to manage a local database of users and passwords
CertificateAuthenticator	Provides services and attributes to manage a local database of users and their X.509v3 certificates
IngressEgress	Provides services and attributes for firewall configuration

TABLE 4. OBJECTS CIP SECURITY ADDS TO A DEVICE

8 of the CIP specification [26]. CIP Security uses open technologies to provide integrity, confidentiality, authentication, and authorization.

- 1) X.509v3 certificates to establish the identity of users and devices
- 2) TLS (Transport Layer Security) and Datagram Transport Layer Security (DTLS) cryptography protocols to provide communications integrity and confidentiality
- 3) Hashes or HMAC to provide data integrity and message authentication to EtherNet/IP traffic
- 4) Proven and standardized encryption algorithms
- 5) OAuth2.0 and OpenID Connect for user authentication with JSON Web Tokens (JWT)

CIP Security adds seven new objects, each containing attributes and services to configure and support CIP Security. These are specified in Volume 8 Section 5 [26] and ODVA white papers [27]. The list of these objects and a description can be found in Table 4.

6.1. Confidentiality, Endpoint Authentication, and Integrity

To provide confidentiality and integrity to CIP messages, CIP Security utilizes TLS 1.2 and DTLS 1.2 as specified in RFC 5246 and RFC 6347 respectively [28], [29]. As TLS operates below the CIP, using TLS does not change the format of any CIP messages. (D)TLS 1.2 also supports mutual device authentication which can be performed with X.509v3 certificates or pre-shared keys (PSK). This allows CIP to perform mutual authentication of both the client and the device. CIP Security allows for the deployment of X.509v3 certificates or PSKs to CIP Security aware devices. Untrusted devices are rejected by TLS mutual authentication. ODVA requires devices to support at least the following cipher suites below for certificate authentication (see [27] for public documentation):

- 1) ECDHE_ECDSA_WITH_NULL_SHA

- 2) ECDHE_ECDSA_WITH_AES_128_CBC_SHA256
- 3) ECDHE_ECDSA_WITH_AES_256_CBC_SHA384
- 4) ECDHE_ECDSA_WITH_AES_128_GCM_SHA256
- 5) ECDHE_ECDSA_WITH_AES_256_GCM_SHA384
- 6) ECDHE_ECDSA_CHA20_POLY1305_SHA256

The following are required for PSK authentication (Volume 8 Section 3-5.5.3):

- 1) ECDHE_PSK_WITH_NULL_SHA256
- 2) ECDHE_PSK_WITH_AES_128_CBC_SHA256
- 3) ECDHE_PSK_WITH_AES_128_GCM_SHA256
- 4) ECDHE_PSK_WITH_CHA20_POLY1305_SHA256

Vendors can add more cipher suites as they choose; however, the ones listed are required. Notice that CIP Security provides options for users to select cipher suites that provide authentication and integrity but not confidentiality. This is intentional, as confidentiality may be undesirable for several reasons (slower performance, blind to IDS, etc.).

The method employed varies depending on the type of connection initiated by the originator (or client).

For connected TCP:

- 1) Originator opens TCP connection to Target's Port 44818
- 2) Target responds and opens a connection with the Originator
- 3) Originator and Target open TLS session
- 4) Once the TLS session is established, the originator sends a CIP Forward_Open packet to establish a CIP connection
- 5) Data is exchanged between the originator and the Target
- 6) Either side can send the Forward_Close packet to close the connection
- 7) TLS and TCP session are closed

For connected UDP:

- 1) Originator starts a DTLS session Target's UDP port 2221
- 2) Target responds and opens a DTLS with the Originator
- 3) Once the DTLS session is established, the originator sends a CIP Forward_Open packet to establish a CIP connection
- 4) Data is exchanged between the originator and the Target
- 5) Either side can send the Forward_Close packet to close the connection
- 6) DTLS session is closed

6.2. User Authentication & Authorization

CIP, without CIP Security enabled, does not naively support user authentication or authorization. This leaves devices vulnerable to unauthorized modification. CIP Security fixes this problem by allowing vendors to support an additional optional profile, the CIP User Authentication Profile (specified in Volume 8 Section 4-2). The CIP User

Authentication profile allows for user authentication via username/password, X.509v3 certificates, or OpenID Connect & OAuth2.0. As of this writing, **no publicly available devices or libraries support CIP User Authentication**; thus, we could not test or evaluate this security feature.

6.3. CIP Security Properties

Table 5 shows the various properties EtherNet/IP and EtherNet/IP with CIP Security provided as outlined by Dzung *et al.* [6]. EtherNet/IP without CIP Security does not provide any of the properties in Dzung *et al.* On the other hand, EtherNet/IP with CIP Security fulfills some of these properties.

CIP Security allows users to configure the TLS cipher suites to enable confidentiality and integrity. This prevents the man-in-the-middle attacks detailed in Section 4.1. However, it is up to the user to enable confidentiality in their environment (thus a partial mark for confidentiality with CIP Security). Additionally, as TLS does not provide non-repudiation, CIP Security does not support non-repudiation. Recent work has proposed adding non-repudiation to the TLS protocol [30]. However, this work has not been adopted by the IETF.

As mentioned in Section 6.2, CIP Security does provide user authentication and authorization. However, no CIP Security devices on the market today implement this functionality. Additionally, the most current CIP Security specification (version 1.17) has a static set of six roles (Administrator, Engineer, Operator, Auditor, Viewer, and Anonymous) [26]. It is up to the vendor to determine which role should be allowed to perform an action on a CIP object. The specification hints at adding support in the future for dynamic, user-created roles.

CIP Security performs mutual device authentication for the originator and the target via a PSK or a X.509v3 certificate. CIP Security prevents unknown devices from communicating with the CIP Security-enabled device. CIP Security also somewhat protects availability, as only authenticated devices can connect and communicate with the target. **However, CIP Security does not fully prevent an authenticated device from executing the Forward_Open DoS attack as detailed in Section 6.**

The CIP Security (and by extension CIP) does not provide any auditability features. This leaves auditing to the vendors to implement their criteria and solutions for auditing [31]. As more vendors implement CIP Security, the lack of specification could create an inconsistent landscape and leave users blind to potential intrusions.

7. CIP Security Limitations

This section describes the current limitations in adopting CIP Security.

7.1. Limited Adoption

CIP Security has minimal hardware and software support. According to ODVA, Rockwell Automation is the

	EtherNet/IP without CIP Security	EtherNet/IP with CIP Security
Confidentiality	○	●
Integrity	○	●
Availability	○	●
Authentication	○	●
Authorization	○	●
Auditability	○	○
Non-reputability	○	○
Third-Party Protection	○	●

TABLE 5. SECURITY PROPERTIES PROVIDED BY ETHERNET/IP AND ETHERNET/IP WITH CIP SECURITY

only company certified to support CIP Security in 14 of its product lines [32]. Popular open-source CIP libraries such as OpENer [33] do not support CIP Security despite having an open GitHub issue since 2018. The authors could find **no open source library that supports CIP Security**. This severely limits the implementation of CIP Security. Users wishing to employ CIP Security site-wide must only use devices currently supporting CIP Security. Otherwise, they must allow insecure devices to connect to CIP Security-enabled devices – potentially allowing attacks mentioned in Section 4. Rockwell Automation only supports CIP Security in its newest product lines. Thus, end users must upgrade from older models in order to deploy CIP Security.

A notable contrast emerges between CIP and other OT protocols such as Open Platform Communication Unified Architecture (OPC UA) regarding message security. OPC UA offers extensive flexibility, allowing developers to select supported SecurityPolicies and SecurityModes. However, this can enable developers to choose insecure or now obsolete algorithms [34]. Conversely, CIP Security imposes the adoption of multiple algorithms for message transmission at the cost of increased complexity for developers.

7.2. Legacy Devices

Industrial devices have been in the field for decades. More than 50 billion dollars worth of industrial systems are over twenty years old [35]. Many of these legacy devices were designed without cryptographic coprocessors, which made cryptographic operations impractical. Even devices that do support cryptography, efforts need to be made to “future-proof” these devices for decades. These legacy devices leave a challenge for protocol designers – how can they design a protocol that will maintain its security properties decades into the future? Twenty years ago (2004), 3DES was commonly used, with AES only standardized in 2001. There is no telling what encryption or algorithms will still be secure decades from now.

8. Conclusion

In this paper, we have provided a comprehensive overview of the EtherNet/IP protocol and conducted an in-depth security analysis. We examined potential vulnerabilities associated with the protocol in the absence of CIP

Security, highlighting various attack vectors. Our analysis also demonstrates that, even with CIP Security protocols in place, it remains feasible to disrupt connected sessions involving other devices. We demonstrated how a series of Forward_Opens can cause a denial of service attack lasting hours. Additionally, we have explored the possibility of downgrading client devices through insecure connection attempts. Lastly, this paper addresses the challenges associated with implementing CIP Security, with particular emphasis on the insufficient support from vendors.

In the future, we hope to use the ADTree outlined in Section 4 to further study the CIP protocol. We hope to map the MITRE ICS ATT&CK Framework to the ADTree to demonstrate the real-world implications of attacking the CIP protocol. We also plan on adding more CIP Security countermeasures to the ADTree. This will allow us to understand CIP better on a technical level.

9. Acknowledgements

The first author is supported by a scholarship through NSF award #2235080. This project has also received support from Rockwell Automation. The authors bear the sole responsibility for the content presented in this paper, and any interpretations or conclusions drawn from it do not reflect the official position of Rockwell Automation. The authors would also like to thank the anonymous reviewers for their comments.

References

- [1] A. Mirian, Z. Ma, D. Adrian, M. Tischer, T. Chuenchujit, T. Yardley, R. Berthier, J. Mason, Z. Durumeric, J. A. Halderman, and M. Bailey, “An Internet-wide view of ICS devices,” in *2016 14th Annual Conference on Privacy, Security and Trust (PST)*, 2016, pp. 96–103.
- [2] A. Cherepanov and R. Lipovsky, “Industroyer: Biggest threat to industrial control systems since Stuxnet,” Jun. 2017. [Online]. Available: <https://www.welivesecurity.com/2017/06/12/industroyer-biggest-threat-industrial-control-systems-since-stuxnet/>
- [3] P. Smith, “New Insights into GhostSec Attacks on Iran’s Infrastructure,” Oct. 2022. [Online]. Available: <https://blog.scadafence.com/ghostsec-attacks-on-iranian-infrastructure>
- [4] Dragos Inc., “Dragos Enabled Defense Against APT Exploits for Rockwell Automation ControlLogix,” Available at <https://www.dragos.com/blog/mitigating-cves-impacting-rockwell-automation-controllogix-firmware/> (2023/07/12).
- [5] B. Batke, D. Dubé, and J. Wiberg, “CIP Security Phase 1: Secure Transport for EtherNet/IP,” Ann Arbor, MI, USA, 2015.
- [6] D. Dzung, M. Naedele, T. Von Hoff, and M. Crevatin, “Security for Industrial Communication Systems,” *Proceedings of the IEEE*, vol. 93, no. 6, pp. 1152–1177, 2005.
- [7] Damm, Gappmeier, Zugfil, Plöb, Fiat, and Störckuh, “OPC UA Security Analysis.” Federal Office for Information Security (BSI), 2017. [Online]. Available: https://opcfoundation.org/wp-content/uploads/2017/04/OPC-UA_security_analysis-OPC-F-Responses-2017_04_21.pdf
- [8] J. vom Dorp, S. Merschjohann, D. Meier, F. Patzer, M. Karch, and C. Haas, “OPC UA Security Analysis.” Federal Office for Information Security (BSI), 2022. [Online]. Available: <https://opcfoundation.org/wp-content/uploads/2023/11/BSI-OPCUA-2022-EN.pdf>

- [9] A. Volkova, M. Niedermeier, R. Basmadjian, and H. de Meer, "Security Challenges in Control Network Protocols: A Survey," *IEEE Communications Surveys & Tutorials*, vol. 21, no. 1, pp. 619–639, 2019.
- [10] F. Tacliad, T. D. Nguyen, and M. Gondree, "DoS Exploitation of Allen-Bradley's Legacy Protocol through Fuzz Testing," in *Proceedings of the 3rd Annual Industrial Control System Security Workshop*, ser. ICSS 2017. New York, NY, USA: Association for Computing Machinery, 2017, p. 24–31. [Online]. Available: <https://doi.org/10.1145/3174776.3174780>
- [11] H. Wu, L. Gong, A. Liu, Y. Zhang, and J. Yang, "Enipfuzz: A seqgan-based ethernet/ip protocol fuzzing test framework," in *2022 IEEE 5th International Conference on Electronics Technology (ICET)*, 2022, pp. 1278–1282.
- [12] A. Ayub, H. Yoo, and I. Ahmed, "Empirical Study of PLC Authentication Protocols in Industrial Control Systems," in *2021 IEEE Security and Privacy Workshops (SPW)*, 2021, pp. 383–397.
- [13] ODVA Inc., "Industrial Automation, Technologies and Standards," Available at <https://odva.org> (2024/03/12).
- [14] ODVA, Inc., "The CIP Networks Library Volume 1: Common Industrial Protocol Edition 3.35," Nov. 2023. [Online]. Available: Upon request to licensed parties
- [15] V. Schiffer, "The Common Industrial Protocol (CIP™) and the Family of CIP Networks," Ann Arbor, MI, USA, 2016. [Online]. Available: https://www.odva.org/wp-content/uploads/2020/06/PUB00123R1_Common-Industrial_Protocol_and_Family_of_CIP_Networks.pdf
- [16] J. Rinaldi and J. Wendorf, *EtherNet/IP: The Everyman's Guide to The Most Widely Used Manufacturing Protocol*. Independently published, 2018.
- [17] B. Kordy, S. Mauw, S. Radomirović, and P. Schweitzer, "Foundations of Attack-Defense Trees," in *Formal Aspects of Security and Trust*, P. Degano, S. Etalle, and J. Guttman, Eds. Berlin, Heidelberg: Springer Berlin Heidelberg, 2011, pp. 80–95.
- [18] B. Hyder and M. Govindarasu, "A Novel Methodology for Cybersecurity Investment Optimization in Smart Grids using Attack-Defense Trees and Game Theory," in *2022 IEEE Power & Energy Society Innovative Smart Grid Technologies Conference (ISGT)*, 2022, pp. 1–5.
- [19] X. Ji, H. Yu, G. Fan, and W. Fu, "Attack-defense trees based cyber security analysis for CPSs," in *2016 17th IEEE/ACIS International Conference on Software Engineering, Artificial Intelligence, Networking and Parallel/Distributed Computing (SNPD)*, 2016, pp. 693–698.
- [20] E. Rios, A. Rego, E. Iturbe, M. Higuero, and X. Larrucea, "Continuous Quantitative Risk Management in Smart Grids Using Attack Defense Trees," *Sensors*, vol. 20, no. 16, 2020. [Online]. Available: <https://www.mdpi.com/1424-8220/20/16/4404>
- [21] G. PETRICĂ, "Cybersecurity of wordpress platforms. an analysis using attack-defense trees method," *International Conference on Cybersecurity and Cybercrime*, vol. 9, p. 69–76, Apr. 2022. [Online]. Available: <https://proceedings.cybercon.ro/index.php/ic3/article/view/2022-09>
- [22] J. Eisentraut, S. Holzer, K. Klioba, J. Křetínský, L. Pin, and A. Wagner, "Assessing Security of Cryptocurrencies with Attack-Defense Trees: Proof of Concept and Future Directions," in *Theoretical Aspects of Computing – ICTAC 2021*, A. Cerone and P. C. Ölveczky, Eds. Cham: Springer International Publishing, 2021, pp. 214–234.
- [23] M. Clifford, M. Heller, K. Levitt, and M. Bishop, "Autonomous Vehicle Security: Composing Attack, Defense, and Policy Surfaces," in *Proceedings of the 2022 New Security Paradigms Workshop*, ser. NSPW '22. New York, NY, USA: Association for Computing Machinery, 2023, p. 90–103. [Online]. Available: <https://doi.org/10.1145/3584318.3584325>
- [24] S. Brizinov, "Bypassing Rockwell Automation Logix Controllers' Local Chassis Security Protection," 2024. [Online]. Available: <https://claroty.com/team82/research/bypassing-rockwell-automation-logix-controllers-local-chassis-security-protection>
- [25] Rockwell Automation Inc., "EtherNet/IP Secure Communication," 2015. [Online]. Available: https://literature.rockwellautomation.com/idc/groups/literature/documents/rm/secure-rm001_-en-p.pdf
- [26] ODVA, Inc., "The CIP Networks Library Volume 8: CIP Security Edition 1.17," Nov. 2023. [Online]. Available: Upon request to licensed parties
- [27] M. Mann, R. Floyd, J. Visoky, and J. Wiberg, "A Practical Guide for CIP Security Device Developers," Ann Arbor, MI, USA, 2017. [Online]. Available: https://www.odva.org/wp-content/uploads/2021/09/2017-ODVA-Conference_Floyd_Mann_Visoky_Wiberg_CIP_Security_Guide_FINAL.pdf
- [28] E. Rescorla and T. Dierks, "The Transport Layer Security (TLS) Protocol Version 1.2," RFC 5246, Aug. 2008. [Online]. Available: <https://www.rfc-editor.org/info/rfc5246>
- [29] E. Rescorla and N. Modadugu, "Datagram Transport Layer Security Version 1.2," RFC 6347, Jan. 2012. [Online]. Available: <https://www.rfc-editor.org/info/rfc6347>
- [30] H. Ritzdorf, K. Wüst, A. Gervais, G. Felley, and S. Capkun, "TLS-N: Non-repudiation over TLS Enabling Ubiquitous Content Signing," *Proceedings 2018 Network and Distributed System Security Symposium*, 2018. [Online]. Available: https://www.ndss-symposium.org/wp-content/uploads/2018/02/ndss2018_09-4_Ritzdorf_paper.pdf
- [31] Rockwell Automation Inc., "System Security Design Guidelines," 2023. [Online]. Available: https://literature.rockwellautomation.com/idc/groups/literature/documents/rm/secure-rm001_-en-p.pdf
- [32] ODVA, "ODVA CIP Security Marketplace," Available at <https://marketplace.odva.org/products/#?vendors=all&productTypes=all&deviceTypes=all&docYears=all&categories=all&services=security&page=1&lang=en&view=search&productDisplay=all/> (2024/04/08).
- [33] EIP Stack Group, "OpENer," Available at <https://github.com/EIPStackGroup/OpENer> (2005/06/12).
- [34] A. Erba, A. Müller, and N. O. Tippenhauer, "Security Analysis of Vendor Implementations of the OPC UA Protocol for Industrial Control Systems," in *Proceedings of the 4th Workshop on CPS & IoT Security and Privacy*, ser. CPSIoTSec '22. New York, NY, USA: Association for Computing Machinery, 2022, p. 1–13. [Online]. Available: <https://doi.org/10.1145/3560826.3563380>
- [35] S. D. Sudarsan, D. Mohan, and S. S. Rohit, "Industrial control systems - legacy system documentation and augmentation," in *2018 IEEE 3rd International Conference on Computing, Communication and Security (ICCCS)*, 2018, pp. 167–170.